Technische Hochschule Ingolstadt

Klausur „**Security Engineering in der IT**“
Sommersemester 2023

Studiengang:	Master Cloud Applications und Security Engineering (CASE)
Dozent:	Prof. Dr.-Ing. Hans-Joachim Hof
Datum	15.07.2023
Matrikel-Nr.:	
Raum-Nr.:	J101
Platzziffer:	

Bearbeitungszeit: 90 Minuten

Umfang: 4Aufgaben auf 11 durchnummerierten Blättern einschließlich Deckblatt

Zugelassene Hilfsmittel: keine

Weitere Hinweise:
- Antworten Sie kurz und präzise. Falsche Antworten oder unpräzise Antworten können zu Punktabzug führen.
- Bei Platzmangel benutzen Sie bitte die Rückseite des vorhergehenden Blattes. Der verfügbare Platz reicht bei normaler Schriftgröße für eine korrekte Lösung aus.

Tipp: lesen Sie die Aufgaben erst komplett durch, bevor Sie mit der Bearbeitung beginnen

Bewertung (wird vom Prüfer ausgefüllt):

	1	2	3	4	Summe	Note
Punkte						
Zweit-korrek-tur						

Aufgabe 1: Kryptographie (21 Punkte)

a) Es sind folgende Szenarien gegeben:

Szenario 1: Ein Betriebssystem führt nur Code aus, der von einem bekannten Herausgeber stammt.

Szenario 2: Ein Whistleblower-Portal (= Webseite für Hinweisgeber auf z.B. kriminelles oder unethisches Verhalten) nimmt verschlüsselte Dateien entgegen. Die Anonymität der Sender ist wichtig.

Szenario 3: Eine Webanwendung greift auf eine Liste mit Kreditkartendaten zu. Die Zugriffe geschehen nur durch diese Webanwendung. Die Liste soll verschlüsselt werden.

Szenario 4: Der Vorstand eines Unternehmens möchte bei einer digitalen Abstimmung sicherstellen, dass das Votum eines jeden Vorstandsmitglieds nachvollziehbar ist.

Wählen Sie durch Ankreuzen in der Tabelle für die einzelnen Szenarien, ob sich ein symmetrisches Verfahren (sym) oder ein asymmetrisches Verfahren (asym) besser eignet. Begründen Sie Ihre Entscheidung:

Szenario Nr.	Asym	Sym	Begründung
1			
2			
3			
4			

b) Skizzieren Sie grafisch die Entschlüsselung im CBC Modus. Sie dürfen die Entschlüsselungsfunktion als einen Block darstellen.

c) Warum wird bei Verwendung einer Blockchiffre im CTR-Modus der Counter verschlüsselt und nicht der Klartextblock?

d) Es existieren aktuell bereits experimentelle Prototypen von Quantencomputern. Warum können trotzdem aktuell noch traditionelle asymmetrische Verschlüsselungsmethoden verwendet werden? Begründen Sie Ihre Antwort.

Aufgabe 2: Reifegrade und Security Testing (25 Punkte)

a) Ihr Unternehmen verwendet SSE-CMM zur Beurteilung des Softwareentwicklungsprozesses. Aktuell befindet sich der Prozess auf Reifegrad 2. Sie sind in der Unternehmensführung für den Bereich „Security Testing“ verantwortlich. Schlagen Sie drei konkrete Maßnahmen vor, die geeignet sind, um im Bereich Security Testing den Prozess von Reifegrad 2 auf Reifegrad 3 zu bringen.

Maßnahme 1:

Maßnahme 2:

Maßnahme 3:

b) Sie sind bei einem Softwarehersteller für die Security der Supply Chain verantwortlich. Sie sind ein Fan von OpenSAMM und würden dieses Modell gerne als Basis der Supply Chain Security verwenden. Was fehlt in OpenSAMM, um es in diesem Kontext einzusetzen?

c) Ordnen Sie die **Aktivitäten** aus dem OWASP Testing Framework den **Aktivitäten** im Microsoft Security Development Lifecycle (in der in der Vorlesung vorgestellten Form) zu.

d) Sie führen eine Bedrohungs- und Risikoanalyse unter Verwendung des OWASP Risk Ratings für eine Online-Banking Webseite durch. Sie betrachten die Bedrohung „Durchprobieren von Passwörtern beim Kundenlogin“.
   - Welchen Angreifer nehmen Sie an?
   - Geben Sie für diese Bedrohung die Bewertungen für die Faktoren von „Threat Agend“ und „Vulnerability“ an.
   - Welche Gesamtwahrscheinlichkeit hat diese Bedrohung?

Aufgabe 3: Sicherheitsarchitektur (21 Punkte)

Sie erstellen ein Security Architecture Pattern nach OSA für den VPN-Zugang in ein Unternehmensnetzwerk

a) Welche Akteure (Actors) benötigen Sie für das Pattern?

b) Welche Komponenten benötigen Sie unbedingt für das Pattern?

c) Nennen Sie acht Security Controls (insgesamt) aus dem OSA Katalog und geben Sie an, auf welchen Komponenten im Szenario VPN-Zugang Sie diese sinnvollerweise implementieren.

1.)

2.)

3.)

4.)

5.)

6.)

7.)

8.)

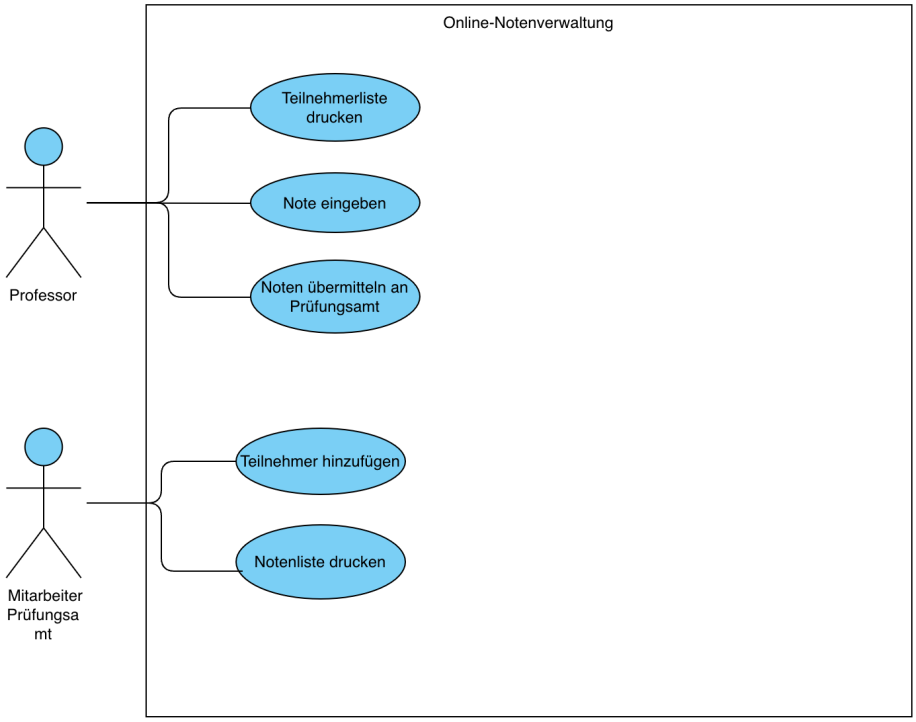
d) Skizzieren Sie das Pattern

Aufgabe 4: Sicherheitsmodellierung (23 Punkte)

a) Ampeln in Ingolstadt messen über Sensoren regelmäßig die Bodeneigenschaften und schalten auf Rot, wenn sie Glatteis feststellen. Aktivisten der „Letzten Generation“ nutzen nun Kältespray, um den Sensoren der Ampeln Glatteis vorzuspiegeln und somit den Verkehr in Ingolstadt zum Erliegen zu bringen.

Modellieren Sie den Angreifer in diesem Szenario nach dem Ponikwar-Hof-Modell:

b) Ergänzen Sie das folgende UML Use Case Diagramm so, dass daraus ein sinnvolles Misuse Case Diagramm entsteht.



c) Beschreiben Sie, wie in UMLsec Angreifermodelle genutzt werden. Wie können diese Angreifermodelle zur Verifizierung von Sicherheitseigenschaften genutzt werden?